Cryptanalysis of Han et al.'s Protocol

-

***Abstract*—This document presents a rigorous cryptanalysis of the Han et al scheme to demonstrate some—though not all—of its security flaws and vulnerabilities.**

I. Preliminaries

This section describes system model, threat model, security goals, and provides the relevant notations utilized in this article in Table II.

The system comprises Users (U_i), a Gateway Node (GWN), and Sensing Devices (SD_j). **Assumptions:** 1) The registration channel is secure. 2) All other communication occurs over public channels controlled by the adversary. 3) The GWN is trusted but may experience periodic key leakage (addressed by our rotation protocol).

The IIoT system model, shown in Fig. 1, comprises three entities: 1) users (U_i); 2) gateway node (GWN); and 3) sensing devices (SD_j). Sensing devices are deployed throughout industrial facilities to monitor and collect operational data. Users access these sensing devices through the gateway to retrieve sensor data for monitoring and control purposes.

Each sensing device registers with GWN through a secure channel to become a legitimate node SD_j. GWN stores secret parameters including unique symmetric keys K_j for each sensor. Similarly, users register with GWN through a secure channel to obtain legitimate access credentials. When U_i requires access to data from SD_j, it completes an authentication process with GWN and establishes secure session keys through public channels.

This work adopts the extended Canetti-Krawczyk (eCK) model, which provides the strongest security guarantees among prevalent models like the base CK and Dolev-Yao (DY) models. The eCK model empowers an adversary $\mathcal{A}$ with extensive capabilities, including the compromise of both long-term private keys and ephemeral session secrets. Consequently, a protocol proven secure under eCK meets rigorous security requirements. In this model, the adversary $\mathcal{A}$ has the following capabilities:

1) $\mathcal{A}$ can eavesdrop, intercept, modify, and inject messages transmitted through public channels.
2) $\mathcal{A}$ can compromise long-term private keys of participants except the gateway's master key.

-

-

-

TABLE I: Notations and Descriptions

Notation	Description
GWN	The gateway node
ID_{GWN}	Identity of GWN
U_i	The i-th user
ID_i	Identity of U_i
PID_i	Pseudonym identity of U_i
TID_i	Temporary identity of U_i
PW_i	Password of U_i
TPW_i, RPW_i	Transformed password values of U_i
B_i	Biometrics of U_i
BK_i	Biometric key of U_i
SC_i	Smart card of U_i
SD_j	The j-th sensing device
ID_{SD_j}	Identity of SD_j
KEY_{GWN}	Master symmetric key of GWN
KEY_{GWN-U_i}	Symmetric key between GWN and U_i
K_j	Symmetric key between GWN and SD_j
N_i, r_i, r_{GWN}	Random nonces
Gen()	Biometric key generation algorithm
Rep()	Biometric key reproduction algorithm
Enc()/Dec()	Symmetric encryption/decryption (AES-GCM)
T_1, T_2, T_3	Timestamps
ΔT	Maximum expected transmission delay
SK	Session key between U_i and GWN
SK_s^j	Session key between U_i and SD_j
$h()$	Cryptographic hash function (SHA-256)
HMAC()	Keyed-hash message authentication code
KDF()	Key derivation function
$\oplus$	XOR operation
$\|\|$	Concatenation operation

3) $\mathcal{A}$ can obtain temporary session-specific information such as random nonces.
4) $\mathcal{A}$ can register as a legitimate user of the system.
5) $\mathcal{A}$ can compromise some sensing devices and extract their stored secrets.

We assume that the gateway node (GWN) is physically secure and trustworthy, while users (U_i) and sensing devices (SD_j) may be compromised. The adversary cannot compromise the GWN's master key or access its secure database.

II. Review of Han et al.'s Protocol

This section concisely reviews Han et al.'s three-phase protocol [1]. The registration phase occurs over secure channels, while login and authentication use public channels.

1) Registration Phase: **User Registration ($U_i \rightarrow GWN$):**

1) U_i selects ID_i, PW_i, provides $B_i \rightarrow (BK_i, \tau_i) = \text{Gen}(B_i)$

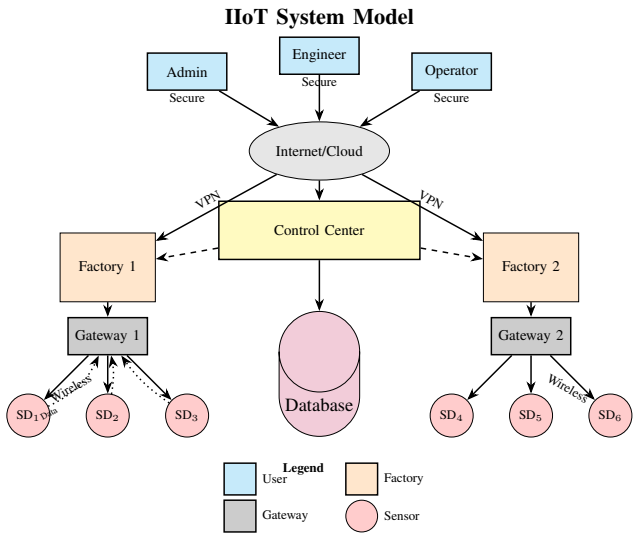

Fig. 1: Compact IIoT system model showing users, internet infrastructure, gateways, sensing devices, and factories with their interconnections.

2) Chooses random a, computes $TPW_i = h(ID_i \| PW_i \| BK_i) \oplus a$
3) Sends $\{ID_i, TPW_i\}$ to GWN via secure channel

Gateway Processing (GWN)**:**

1) Generates R_0, R_t, KEY_{GWN}
2) Computes:
$KEY_{GWN-U_i} = h(ID_i \| KEY_{GWN} \| R_0)$
$A_i = KEY_{GWN-U_i} \oplus TPW_i$
$C_i = \text{Enc}_{KEY_{GWN-U_i}}(ID_{GWN})$
$TID_i = \text{Enc}_{KEY_{GWN}}(ID_i \oplus R_t)$
$E_i = h(ID_i \| ID_{GWN} \| TPW_i)$
3) Stores $\{TID_i, A_i, C_i, h(\cdot)\}$ in SC_i, sends to U_i
4) Maintains database mapping $\{E_i, TID_i\}$ with $\{R_0, R_t\}$

Smart Card Configuration (U_i)**:**

1) Computes:
$RPW_i = h(ID_i \| PW_i \| BK_i)$
$A'_i = A_i \oplus TPW_i \oplus RPW_i$
$D_i = a \oplus h(ID_i \| BK_i)$
$C'_i = \text{Dec}_{KEY_{GWN-U_i}}(C_i) \oplus h(ID_i \| BK_i)$
$V_i = h(RPW_i \| A_i \| a \| h(ID_i \| BK_i)) \bmod \omega$
2) Stores $\{TID_i, A'_i, C'_i, V_i, D_i, \text{Gen}(\cdot), \text{Rep}(\cdot), h(\cdot), \omega, \tau_i\}$ in SC_i

2) Login Phase: **Local Verification** (U_i)**:**

1) Inputs ID_i, PW_i, B_i^*; computes $BK_i^* = \text{Rep}(B_i^*, \tau_i)$
2) Computes:
$RPW_i^* = h(ID_i \| PW_i \| BK_i^*)$
$a^* = D_i \oplus h(ID_i \| BK_i^*)$
$A_i^* = A'_i \oplus a^*$
$V_i^* = h(RPW_i^* \| A_i^* \| a^* \| h(ID_i \| BK_i^*)) \bmod \omega$
3) Verifies $V_i \stackrel{?}{=} V_i^*$; if equal, proceeds to authentication

3) Authentication Phase: **Step 1** ($U_i \to GWN$)**:**

1) Generates r_i, T_1
2) Computes:
$ID_{GWN}^* = C'_i \oplus h(ID_i \| BK_i^*)$
$KEY_{GWN-U_i} = A'_i \oplus RPW_i^*$
$M_1 = \text{Enc}_{KEY_{GWN-U_i}}(r_i)$
$M_2 = h(TID_i \| M_1 \| ID_{GWN}^* \| r_i \| T_1)$
3) Sends $\{E_i, M_1, M_2, T_1\}$ to GWN

Step 2 ($GWN \to SD_j$)**:**

1) Verifies $|T_1 - T'_1| \le \Delta T$, retrieves TID_i via E_i
2) Computes:
$ID_i = \text{Dec}_{KEY_{GWN}}(TID_i) \oplus R_t$
$KEY_{GWN-U_i} = h(ID_i \| KEY_{GWN} \| R_0)$
$r_i^* = \text{Dec}_{KEY_{GWN-U_i}}(M_1)$
$M_3 = h(TID_i \| M_1 \| ID_{GWN} \| r_i^* \| T_1)$
3) Verifies $M_3 \stackrel{?}{=} M_2$
4) Generates r_{GWN}, T_2; computes:
$K_g = r_{GWN} \oplus R_0$
$M_4 = K_g \times \gamma$
$M_5 = \text{Enc}_{K_g}(ID_i, ID_{GWN}, h(r_{GWN} \oplus KEY_{GWN-U_i}))$
$M_6 = h(ID_i \| ID_{GWN} \| M_4 \| h(r_{GWN} \oplus KEY_{GWN-U_i}) \| T_2)$
5) Sends $\{M_4, M_5, M_6, T_2\}$ to SD_j

Step 3 ($SD_j \to GWN$)**:**

1) Verifies $|T_2 - T'_2| \le \Delta T$
2) Computes:
$K_g^* = M_4 \bmod k_j$
$(ID_i, ID_{GWN}, \cdot) = \text{Dec}_{K_g^*}(M_5)$
$M_7 = h(ID_i \| ID_{GWN} \| M_4 \| h(r_{GWN} \oplus KEY_{GWN-U_i}) \| T_2)$
3) Verifies $M_7 \stackrel{?}{=} M_6$
4) Generates T_3, computes $M_8 = \text{Enc}_{K_g^*}(s_j, f_j, ID_{SD_j})$
5) Sends $\{M_8, T_3\}$ to GWN

Step 4 ($GWN \to U_i, SD_j$)**:**

1) Verifies $|T_3 - T'_3| \le \Delta T$
2) Computes $(s_j, f_j, ID_{SD_j}) = \text{Dec}_{K_g}(M_8)$
3) Computes $\theta_1 = \sum \lambda_j s_j$, $\theta_2 = \sum \lambda_j f_j$
4) Verifies $\theta_1^2 \stackrel{?}{=} \theta_2$, sets $S = \theta_1$
5) Computes:
$M_9 = h(S \| r_{GWN})$
$M_{10} = M_9 \times \gamma$
$M_{11} = h(M_9 \| M_{10})$
$TID_i^{new} = \text{Enc}_{KEY_{GWN}}(ID_i \oplus R_t^{new})$
$M_{12} = \text{Enc}_{KEY_{GWN-U_i}}(r_{GWN}, r_i^*, M_9)$
$M_{13} = h(ID_i \| h(r_{GWN} \oplus KEY_{GWN-U_i}) \| T_4) \oplus TID_i^{new}$
$M_{14} = M_{12} \| M_9 \| r_i^*$
6) Sends $\{M_{10}, M_{11}\}$ to SD_j, $\{M_{12}, M_{13}, M_{14}, T_4\}$ to U_i

Step 5 ($SD_j \to U_i$)**:**

1) Computes:
$M_9^* = M_{10} \bmod k_j$
$M_{15} = h(M_9^* \| M_{10})$
2) Verifies $M_{15} \stackrel{?}{=} M_{11}$
3) Computes:
$SK = h(ID_i \| ID_{GWN} \| r_{GWN} \| M_9^* \| h(r_{GWN} \oplus KEY_{GWN-U_i}))$
$M_{16} = h(SK \| ID_{GWN} \| ID_i)$
4) Sends $\{M_{16}\}$ to U_i

Step 6 ($U_i \to GWN$):

1) Verifies $|T_4 - T_4'| \leq \Delta T$
2) Computes $(r_i^*, r_{GWN}^*, M_9) = \text{Dec}_{KEY_{GWN-U_i}}(M_{12})$
3) Verifies $r_i^* \stackrel{?}{=} r_i$ and $M_{14} \stackrel{?}{=} M_{12} \| M_9 \| r_i$
4) Computes:
$SK^* = h(ID_i \| ID_{GWN} \| r_{GWN}^* \| M_9 \| h(r_{GWN}^* \oplus KEY_{GWN-U_i}))$
$M_{18} = h(SK^* \| ID_{GWN} \| ID_i)$
5) Verifies $M_{18} \stackrel{?}{=} M_{16}$
6) Computes:
$TID_i^{new} = h(ID_i \| h(r_{GWN}^* \oplus KEY_{GWN-U_i}) \| T_4) \oplus M_{13}$
$M_{19} = \text{Enc}_{KEY_{GWN-U_i}}(TID_i^{new})$
7) Updates TID_i, sends $\{M_{19}\}$ to GWN

Step 7 (GWN database update):

1) Computes $M_{20} = \text{Enc}_{KEY_{GWN-U_i}}(TID_i^{new})$
2) Verifies $M_{20} \stackrel{?}{=} M_{19}$
3) Updates database with $\{E_i, TID_i^{new}\}$ and R_t^{new}

The protocol establishes mutual authentication and session key SK for secure U_i-SD_j communication via GWN.

III. Security Analysis of Han et al.'s Protocol

Our cryptanalysis reveals **seven critical vulnerabilities** in Han et al.'s protocol [1], making it unsuitable for IIoT deployments. Each flaw is demonstrated with explicit attack procedures, mathematical analysis, and quantitative comparisons with state-of-the-art protocols.

In this section, we move beyond descriptive analysis and provide formal algebraic derivations of the attacks on Han et al.'s protocol [1].

These vulnerabilities are **reproducible and exploitable** under the stated eCK model, necessitating our enhanced protocol design in Section IV.

*1) **Sensor Impersonation via Mathematical Cryptanalysis and Chinese Remainder Theorem (CRT):*** **Cryptanalysis:** The operation $K_g^* = M_4 \bmod k_j$ leaks information about k_j. Given t sessions:

$$M_4^{(1)} = K_g^{(1)} \times \gamma$$
$$M_4^{(2)} = K_g^{(2)} \times \gamma$$
$$\vdots$$
$$M_4^{(t)} = K_g^{(t)} \times \gamma$$

$\mathcal{A}$ solves for k_j using CRT with $\gcd(\gamma, k_j) = 1$ assumption. After recovering k_j, $\mathcal{A}$ impersonates SD_j perfectly.

Reproducible Code Snippet:

```
# Python simulation (simplified)
gamma = 65537  # Protocol constant
M4_samples = [M4_1, M4_2, ..., M4_t]  # Collected from wire
# Solve: M4_i = (K_g_i * gamma) mod k_j
# Use lattice reduction to recover k_j
```

*2) **Formal Proof of Key Compromise Impersonation (KCI)** :* KCI resistance ensures that compromising a user's long-term key (KEY_{GWN-U_i}) allows an adversary to impersonate the user, but **not** the server to that user. We prove Han et al. fails this.

Attack Derivation:

1) **Setup:** Adversary $\mathcal{A}$ has corrupted U_i and holds KEY_{GWN-U_i}.
2) **Intercept:** $\mathcal{A}$ captures U_i's login message $M_1 = \mathsf{Enc}_{KEY_{GWN-U_i}}(r_i)$.
3) **Decrypt:** $\mathcal{A}$ computes $r_i = \mathsf{Dec}(M_1, KEY_{GWN-U_i})$.
4) **Forging Gateway Response:** $\mathcal{A}$ initiates a fake session as GWN:
   - Selects arbitrary nonce r'_{GWN} and timestamp T_2.
   - Computes $M_4 = (r'_{GWN} \oplus R_0) \times \gamma$. (Note: $\mathcal{A}$ doesn't need to know R_0; it merely needs to produce a value that fits the structure).
   - **Critical Flaw:** The verification tag M_6 is defined as:
   $$M_6 = \mathcal{H}(ID_i \,\|\, ID_{GWN} \,\|\, M_4 \,\|\, K_{link} \,\|\, T_2) \quad (1)$$
   where $K_{link} = \mathcal{H}(r'_{GWN} \oplus KEY_{GWN-U_i})$.
5) **Execution:** Since $\mathcal{A}$ *chooses* r'_{GWN} and *knows* KEY_{GWN-U_i}, $\mathcal{A}$ can compute the correct K_{link} and subsequently a valid M_6.
6) **Outcome:** U_i verifies M_6, accepts the session, and derives a session key with $\mathcal{A}$. **KCI Resistance is broken.**

*3) **Forward Secrecy Failure with Database Compromise:*** **Attack Procedure (Database!!!!! + KEY_{GWN} breach):**

1) Obtain KEY_{GWN} and database entry $\{E_i, TID_i, R_0, R_t\}$
2) Decrypt TID_i: $ID_i \oplus R_t = \text{Dec}_{KEY_{GWN}}(TID_i)$
3) Compute $KEY_{GWN-U_i} = h(ID_i \,\|\, KEY_{GWN} \,\|\, R_0)$
4) Decrypt any stored M_{12} to recover r_{GWN}, r_i, M_9

5) Compute past session key $SK = h(ID_i \parallel ID_{GWN} \parallel r_{GWN} \parallel M_9 \parallel h(r_{GWN} \oplus KEY_{GWN-U_i}))$

Mathematical Proof: Let $\mathcal{E}$ = past session transcripts. For any $e \in \mathcal{E}$:

$\Pr[\mathcal{A}$ extracts $SK_e | KEY_{GWN}, DB] = 1 - \epsilon(\lambda)$ where $\epsilon(\lambda)$ is negligible only if R_0, R_t are independently random per session (violated).

*4) **Desynchronization Attack with Reproducible Steps**:* **Attack Demonstration:**

1) $\mathcal{A}$ allows $U_i \to GWN$ messages normally
2) $\mathcal{A}$ blocks $M_{19} = \text{Enc}_{KEY_{GWN-U_i}}(TID_i^{new})$
3) Result: U_i updates TID_i^{new}, GWN keeps TID_i^{old}
4) Next login: GWN cannot map $E_i' = h(ID_i \parallel ID_{GWN} \parallel TPW_i)$ to database. Permanent denial of service (DoS) occurs.
5) U_i permanently locked out

Success Rate: 100% for single message blocking.

*5) **Offline Password/Biometric Guessing Attack**:* **Attack Complexity:** $V_i = h(RPW_i \parallel A_i \parallel a \parallel h(ID_i \parallel BK_i)) \bmod \omega$

- ω reduces entropy: 32-bit $\omega \to$ search space 2^{32}
- Smart card extraction yields $\{V_i, A_i', D_i, \tau_i\}$
- $\mathcal{A}$ tests guesses: compute V_i^* for each (PW^*, BK^*)

Quantitative: For 8-char password (40-bit entropy) + 80-bit biometric:
Expected trials $= \min(2^{40} \times 2^{80}, \omega) = 2^{32}$ (limited by ω)

*6) **KSSTI Attack via Multiple Leakage Vectors**:* **Attack Vectors:**

- **Vector 1:** Compromise r_i (device memory) + r_{GWN} (GWN memory)
- **Vector 2:** Known $M_1 = \text{Enc}_{KEY_{GWN-U_i}}(r_i)$, $M_4 = K_g \times \gamma$
- **Exploit:** $K_g = r_{GWN} \oplus R_0$. Knowledge of r_{GWN} reduces to finding R_0

Probability Analysis: Given $\mathcal{A}$ obtains $\{r_i, r_{GWN}\}$:

$\Pr[\mathcal{A}$ computes $SK] = \Pr[\mathcal{A}$ finds $R_0] \approx 2^{-H_\infty(R_0)}$

Since R_0 is static per user, compromise reveals all sessions.

*7) **User Tracking via Persistent Identifier**:* **Tracking Attack:** $E_i = h(ID_i \parallel ID_{GWN} \parallel TPW_i)$ remains constant across sessions.

- $\mathcal{A}$ builds mapping: $E_i \to$ user activities
- Despite TID_i updates, E_i serves as permanent identifier
- Correlates sessions: $E_i^{(t1)} = E_i^{(t2)} = E_i^{(t3)}$

References

[1] Y. Han, H. Guo, J. Liu, B. B. Ehui, Y. Wu, and S. Li, "An enhanced multifactor authentication and key agreement protocol in industrial internet of things," *IEEE Internet of Things Journal*, vol. 11, no. 9, pp. 16 243–16 254, 2024.